



Is your business GDPR compliant?

Use this checklist to identify gaps in your data protection practices. Each item represents a key GDPR obligation for small and medium-sized businesses operating in the EU. Score 1 point per box ticked.

1. Lawful basis & transparency

- ☐ **We have identified a lawful basis for every type of personal data we process**
Consent, contract, legitimate interest, legal obligation — one of these must apply.
- ☐ **We have a clear and accessible privacy policy published on our website**
Must explain what data you collect, why, and how long you keep it.
- ☐ **We inform individuals at the point of data collection about how their data will be used**
Privacy notice on forms, email sign-ups, or contracts — not just buried in the policy page.
- ☐ **We obtain and record explicit consent where required**
Consent must be freely given, specific, informed and unambiguous — and documented.

2. Data inventory & minimisation

- ☐ **We maintain a record of all personal data we process (data register)**
GDPR Article 30 requires organisations to document their processing activities.
- ☐ **We only collect personal data that is strictly necessary for the stated purpose**
Avoid collecting data 'just in case' — only process what you actually need.
- ☐ **We have a defined retention period for each type of personal data**
Data should not be kept longer than necessary for its purpose.



3. Data subject rights

- ☐ **We have a process for handling subject access requests within 30 days**
Individuals can request a copy of their data — you must respond within one month.
- ☐ **We can delete or correct personal data upon request**
Right to erasure ('right to be forgotten') and right to rectification.
- ☐ **We have a process for handling objections to data processing**
Individuals can object to processing based on legitimate interest.

4. Security & data breaches

- ☐ **We have appropriate technical security measures in place**
Encryption, access controls, strong passwords, regular backups.
- ☐ **We have a written data breach response plan**
Breaches must be reported to Datatilsynet within 72 hours if they pose a risk.
- ☐ **Access to personal data is restricted to authorised personnel only**
Apply the principle of least privilege — only give access where needed.
- ☐ **We use strong passwords and MFA for systems holding personal data**
A basic but critical control — and increasingly an expectation from cyber-insurers.

5. Third parties & data transfers

- ☐ **We have signed Data Processing Agreements with all third-party processors**
CRM, email provider, accounting software, cloud storage — every supplier handling personal data.
- ☐ **Third-country transfers (outside EU/EEA) have a valid legal basis**
Standard Contractual Clauses, adequacy decision, or other Article 46 safeguard.

How did you score?

13–16 Strong foundation Book a call to close the remaining gaps

8–12 Notable gaps These should be addressed soon

0–7 High exposure Contact us for a priority assessment

Not sure where to start?

Book a free 20-minute intro call. We'll review your situation and tell you honestly what to do — no jargon, no obligation.

calendly.com/hello-soroflow/20min →

